perform actions may be indications of an attempted attack. It’s difficult to overstate the importance of good audit logging to the security of an API. Audit logs should be written to durable storage, such as the file system or a database, so that the audit logs will survive if the process crashes for any reason.

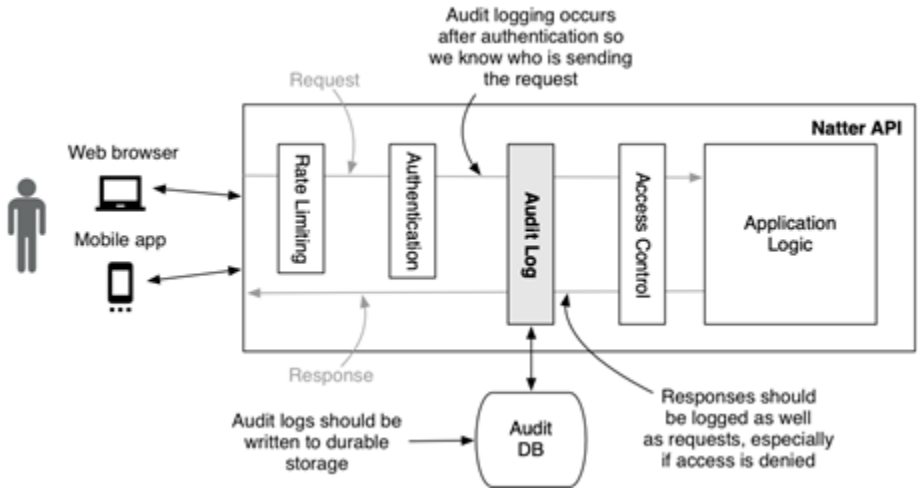


Figure 3.6 Audit logging should occur both before a request is processed and after it completes. When implemented as a filter, it should be placed after authentication, so that you know who is performing each action, but before access control checks so that you record operations that were attempted but denied.

Thankfully, given the importance of audit logging, it’s easy to add some basic logging capability to your API. In this case, you’ll log into a database table so that you can easily view and search the logs from the API itself. In later chapters you’ll look at more comprehensive audit logging capabilities.